

Description: The purpose of this site is to fill in court forms. All information should be entered once and the site will handle the rest.

Security

- **Goal:** Encrypt sensitive fields at the application layer (using deterministic encryption for equality searches) while still enabling MariaDB's tablespace encryption for defense-in-depth. That way you get both compliance-friendly at-rest protection and some control over what the server can actually "see.". Only users who possess a per-tenant key can decrypt sensitive fields (phone, SSN). The server stores only ciphertext and derived indexes. Non-sensitive fields will be decrypted but in the settings will have the option to encrypt them by putting a clickable encryption symbol next to the field.
- **Transport:** Enforce HTTPS everywhere (HSTS), set Secure cookies, disable mixed content.
- AEAD encryption for data confidentiality and integrity.
- Blind indexes (keyed hashes) for equality searches without deterministic encryption of the data itself. To simplify.. if we need to search for a Social Security Number we would encrypt it then search for the keyed hash result of that encryption. Allowing us to match up the data without having the data visible on the server.
- Key-in-cookie model with strict cookie security and no server-side key storage.
 - The site will store an encryption key in the customers/users web browser cookie that will be used to decrypt the data. This way the only people that can access the data are the ones with the encryption key.
 - Storage cookie must be HttpOnly
 - HttpOnly cookie: A cookie flagged HttpOnly cannot be read by JavaScript (document.cookie won't see it).
 - Why it's safer: If an attacker injects malicious JavaScript (XSS), they can't steal the key from an HttpOnly cookie.
 - On each request, the server receives the cookie, derives the crypto keys, and performs encryption/decryption on the server.
 - Downside: The server does see plaintext during crypto operations, so the server must be trusted.
 - During setup a web page that will generate a key for them and store it in a cookie but also give them the ability to backup the key and send it to other users who need access to the data. The key will not be stored on the server at all after that.
 - In the database only the name will be unencrypted. The user will be able to look up persons in the database by their phone number or social security number in the database by comparing hashes.
- Search capability: Equality searches on phone and SSN using blind indexes. Range, prefix, or fuzzy search are intentionally not supported to avoid leaking structure. If needed later, we can discuss advanced searchable encryption trade-offs.
- Don't log inputs or outputs. Ensure backups and replicas preserve binary fidelity.
- **Key Storage:** HTTP cookie named enc_key containing a base64-encoded MK, length 32 bytes (256-bit).
- **Derived keys:**
 - DataKey = HKDF(MK, "data")
 - IndexKey = HKDF(MK, "index:phone"), IndexKeySSN = HKDF(MK, "index:ssn")
 - Why: Key separation prevents cross-use attacks and enables independent rotation if ever needed.
- **PHP frameworks and libraries to look into**
 - **Frameworks (open source):**
 - **Laravel:** Batteries-included, strong security defaults, excellent ecosystem. Eloquent for ORM, queue support for background re-encryption, robust middleware for cookie/session security.
 - **Symfony:** Enterprise-grade components, HTTP kernel, DI container, and Doctrine ORM. Great for modular, testable architecture.
 - **Slim (or Lumen):** Lightweight microframeworks if you want minimal overhead and you'll wire components yourself.
 - **Crypto libraries:**

- **ext-sodium (Libsodium):** Modern, easy-to-use, safe-by-default primitives. Prefer this for AEAD, HKDF, and Argon2id.
- **OpenSSL:** Available everywhere, supports AES-GCM if you prefer AES; APIs are more cumbersome, mind footguns.
- **Paragonie CIPHERSweet (PHP):** Provides field-level encryption with blind indexes out-of-the-box, including Laravel/Symfony integrations. Strongly recommended to avoid homegrown crypto.

Features

- Multiple Firms (Group of login accounts)
- Multiple User Accounts in Firms (Single login account in Firm)
- Multiple Customers in Firms (Data set for firm)
- Assign Customers to Users
 - Ability to restrict Users to only see their customers. **(A)**
- Access levels for Users
- 2FA at Login
- Customize Client Fields for the each individual Client.
- Customize Client Fields for the whole firm.
- In Field, Override populated data or Revert to populated data on a form (with button).
- Auto retrieve Forms
- Upload Forms
- Change sort order of Forms
- Field Text
 - Type and Size of font will be set at Account/Firm level.
 - Then can be overwritten on at a Form level
 - Then can be overwritten on a Field Level on each form.
 - If you reach the end of a field the font color will change and the font will shrink to allow more text in the field. (Auto reduce font size) until the font size cannot be reduced and no more text can be added then the font will turn red.
 - There will be a panel on the right side that will display font information that can be modified.
 - Font Type and Size (No other properties)

Website Flow...

Notes

- Firm -> User -> Selected Client -> Enter (or select) Case -> Selected Forms -> Data -> Form
- All website text to be presented from a variable array retrieved from the database that will allow us to manage the website text virtually. For example \$SITEINTROTEXT would be text shown on the website introduction. All text will be separated by language. This will can be done with a language field.
- Text can be modified inline of the site by double clicking on text when the site is in admin edit mode or admin is logged in. (either/or this is up for discussion)
- **Database Flow:**
 - Do we want to create a fresh table for each firms customer data?
 - Tables
 - Firm (Links to "Users")
 - Users (Links to "Clients")
 - Clients (Links to "Client Data" and "Cases")
 - Client Data (Date that Uses "Client Form Data")
 - Firm Form Data (Same is "Client Form Data" just supplies the template to start the "Client Form Data")

- Client Form Data (Customized list of form fields that will auto-populate the forms. Starts by using the "Firm Form Data")
- Cases (Links to Form Data and Forms)
- Forms (List of available forms for Firm with internal field location data of physical PDF on drive) (Also has an internal link of location to retrieve form updates)

Home Page (A)

- Explanation of website.
- Prices
- [SignIn](#) and [Signup](#) link on top right

Sign-in Page

- Sign in with users email address, password, and Google Authenticator 2FA code.
- Checkbox for Remember Me
- Checkbox for Trust this Device
- Leads to [Dashboard Page](#)

Dashboard Page

- **User Account Menu** (top right corner)
 - Will support profile picture (A)
 - Options
 - @ Change Password
 - Settings" (if we have any)
 - [Encryption Key Page](#) (A??)
 - Users (If Admin) (A)
 - Roles (If Admin) (A)
 - Billing (If Admin) (A)
- **Menu on left block**
 - Note: We can do one or the other "Find" or "Browse" first and leave the other for the next run.
 - @ [Customer Manager]
 - @ [New]
 - [Browse]
 - @ [Case Manager]
 - @ [New]
 - [Browse]
 - @ [Project Manager]
 - @ [New]
 - [Browse]
- **Center Block**
 - Pinned, but removable, notification explaining that "[you create a new customer then add a case then add projects to the case. And the project is where your documents exist.]" (A)
 - Large Icons for [New Customer] [Find Customer] [Find Case] [Find Project] (A)
 - should fit width can be layed out like buttons to give more virtual space for the page and centered.
 - Use the color as a global variable/setting as we will use that to classify locations later.
 - background color of each button will reflect the color assigned to that data category.
 - Pinned Customers / Cases / Projects. (A)
 - Will have the ability to change order and display mode between icon and list. But we will add that later. Make sure to have a field and code to support the order.
 - In icon mode they will have a colored title bar at the top of each icon displaying whether they are a "Customer", "Case", or "Project".
 - Use the color of that data category.

- In list mode we can use a colored dot at the front to indicate the data type or change the background color of the row?

Signup Form Page

- (This section for later phase)
- Incomplete Will fill this out more later...
- When we present the key to the user it must be made clear what this key is for, their data will be lost without it, and that they are going to need to re-enter the key at some point in the future. Perhaps have an "I Understand" checkbox and record that they checked it.

Encryption Key Page

- Numeric key generated by the website is presented to the user.
- Option to email the key or save it as a PDF to their drive.
- Key is HttpOnly and stored in an encrypted cookie on the users drive.

New Case Page

- Text: Case Name
- Text: Case ID
- Select: Type of Case
 - Note: This loads a template with a set of forms after they select it.
- Jurisdiction identifier: Drilldown Dropdown: State -> County -> Court House -> Department
 - "Courtroom Number" empty box they can fill in. We can auto fill that in for them if we can figure it out but let them change it and store it local to the case.
- Button: "Save as Default"
 - Put this button to the right of the "Type of Case" dropdown. Should be invisible or disabled when not applicable.
 - If they choose different forms or change the order this will allow them to update the template on-the-fly for future use.
- When they select the Type of Case the page populates with a list of forms by ID (FM-101) then Description (If it exists). To the right of each form will be a grab handle to drag them and change their order.

Forms Manager Page (Phase 1)...

- Wizard style interface.
- Localize Forms to..
 - Note: do not do this yet. Just create a pane to house it when we do. It will be on the right above the field properties
- Do not automate the form grabbing system in this phase. We will manually upload them.
- Phase one will only use the global form section. Set it up in the database that way. Record the form name and check it against that real quick.
- User can upload forms and modify the fields. Field alignment is stored in the database specific to the Firm.
 - Just the global template for the form at the moment.
- After uploading the form the user can then move fields with drag and drop
 - on a panel on the right under the form location selector panel They will have options to...
 - Default Value. If it is a checkmark literally show a checkbox with it checked or unchecked.
 - Manually set the X and Y Coordinates.
 - Set the field width. (Numeric Input box)
 - Set the field height. (Numeric Input box)
 - Set the field type. (Drop Down)
 - Set the font size. (Numeric Input box)
 - Assign Custom Fields (List all custom fields in dropdown. would be nice if we can figure out a way to make it clear which are Firm level, Client Level, or Case level fields) I am thinking two dropdowns.. one has the 3 locations and the auto-repopulates the second dropdown.

Perhaps have them pre-populated and hide/show the one that applies when the first dropdown is selected)

- Add the ability to add our own fields and also if needed, tie it to a prefilled custom field.
- At the bottom a dropdown with values (Test Form|Actual Form) with Test form being the default (for now). Then an [Export] button to the right of it. Which will download a PDF file with sample values or how it will actually look.
 - Note: For now do not bother with letting them modify the test values. We will circle back to that.
- At bottom put a [Finished] button which will just reset the form to wait for the next upload.

Forms Manager Page...

- Localize Forms..
 - Note: Drill down selector on pain on top. Each selection will populate and reveal the next dropdown.
 - State
 - County
 - Court House
 - Court Room
- Wizard style interface.
- I have to sort this out more but it would be nice if we could automatically grab the form from their local county website just based on the form name. this would involve a firm level setting where they can select from a list or add their own source for finding forms. As firms create their own we could copy them to the global list.
- There will be 2 form sections. One that is global and one that is private to the firms account. A dropdown will switch between which set of forms they are working with.
- User can upload forms and modify the fields. Field alignment is stored in the database specific to the Firm.
- Admin can move firm saved forms to global forms with their alignments.
- Admin can modify global form alignments.
 - Ability to notify users that a form has changed.
- If a user tries to upload a form that already exists as a global form they will be notified and offered to use the global version or cancel the process or continue with their own version.
 - Users can modify the fields for already uploaded forms and store custom settings. We should notify them of this with the above prompt.
- After uploading the form the user can then move and resize fields, change the field type, and download a sample with sample data to view it before saving/submitting it.
 - (Default Data for forms is handled when they fill out the form)
- Once the form is setup the user will be able to assign their custom fields to fields on the form. Pulling from Firm Fields, Client Fields, Or add new custom fields just for the form with the ability to pre-set data within them.

Template Manager Page

- This is where you create the default set of forms for each type of lawsuit.
- They will have the ability to choose from the global preset list or create their own.
- Admins will have the ability to move *copy* firms pre-made lists to the global list.
- User can choose from the built-in global set of forms and then modify it and save it as a private set with a custom name or use the pre-defined name. "Blah blah divorce"
- They will have the ability to select a form and pop over to a temporary form editing page to create custom fields and data specific to that template.

Clients Page

- Wizard Form
- Search box to find existing clients or add a new one.

- Add New Client
 - Preset Fields (TBT) they fill out with info for clients.
 - Ability to add custom fields with type of field and pre-set the default data.
 - Ability to set any custom field to appear on all clients.

Project Page

- Wizard Form
- Search box to list existing projects.
- Button to add new project.
 - Choose Template with dropdown to select from local/private or global templates.
- Add client to project.
- Custom fields listed and filled in with firm and client info.
- Ability to change field data specific to this project.
- Ability to add new custom fields specific to this project.
- Forms in project are listed.
 - Ability to add new forms specific to project
 - Ability to change the order of the forms in the project.
- Hit next and this is where they get the list of forms to fill out and save. See [Fill Out Forms Page](#)

Fill Out Forms Page

- Can change field formatting
- Can add temporary custom fields.
- forms listed on right side under form info panel.
- Data automatically saved to form as they type it in or leave a field box.
- They can save individual forms as PDF files, or the whole project given to them as all the PDF's in a zip file, or one giant PDF file with all pages merged. Just give them a dropdown in the lower right corner or underneath with those options and a single [Export] button.